

SkyTech Security Architecture

Version V1.0 · 2026-10-10 · matches repository release R4.0 · maintained by SkyTech_Manager

How the SkyTech program protects its data, its owner and the businesses it contacts. Industry practices (OWASP ASVS, NIST CSF 2.0, CIS Controls v8) applied to a \$0, one-PC setup: what is protected, against which threats, by which controls, and what the owner does to keep it that way.

Contents

- 1. Security principles
- 2. Data classification
- 3. Trust boundaries
- 4. Threat model (STRIDE)
- 5. Controls and standards mapping
- 6. Secrets and key management
- 7. Logging, monitoring and audit
- 8. Backup and recovery
- 9. Incident response
- 10. Owner security checklist
- 11. Known limits and roadmap

1. Security principles

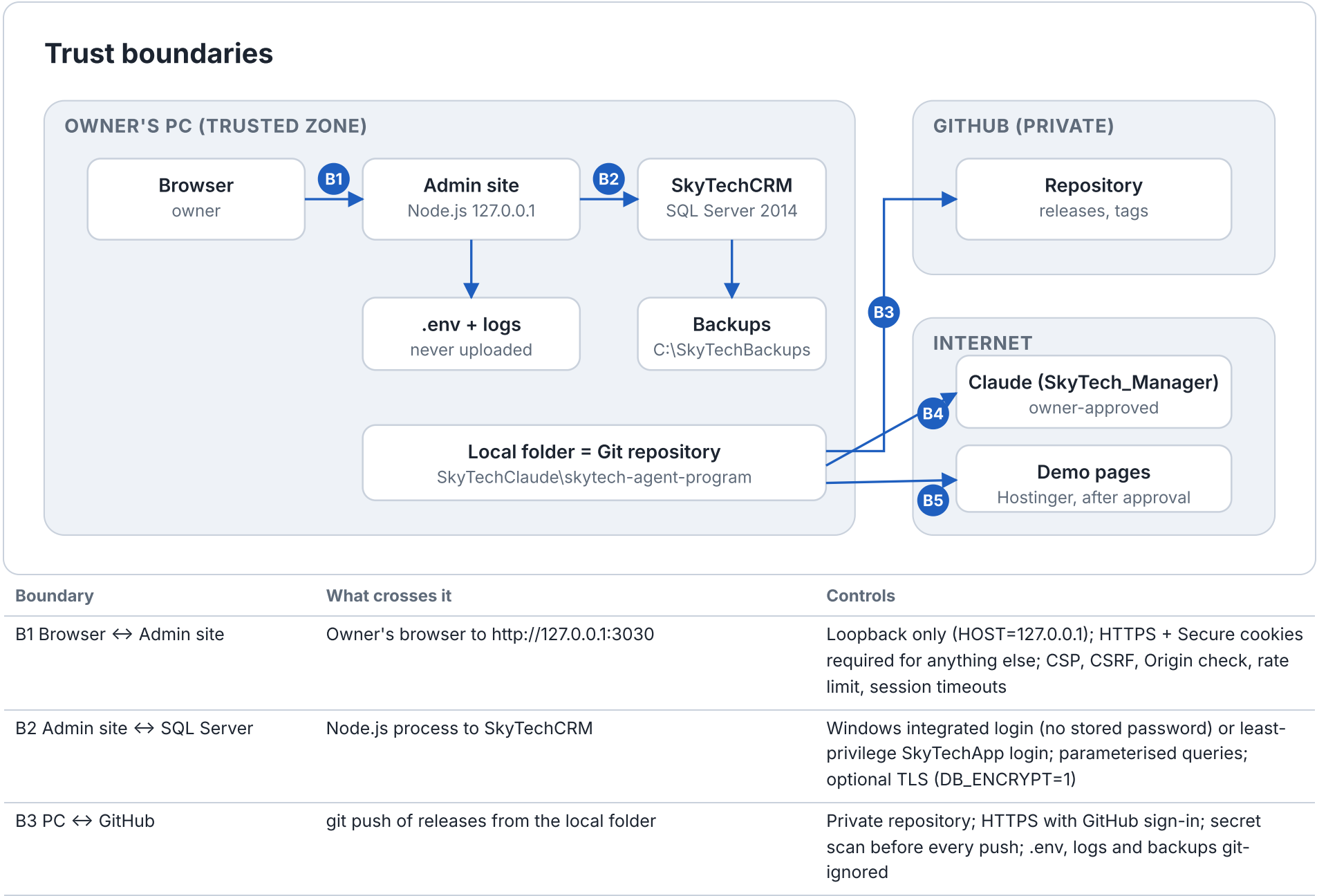
Principle	How SkyTech applies it
Least privilege	Each part gets only the access it needs: viewer vs admin roles in the site; SkyTechApp database role with no design rights; agents act only after the owner approves.
Defence in depth	Several independent layers: local-only network binding, sign-in with lockout, session timeouts, CSRF token + Origin check, strict CSP, parameterised SQL, whitelisted tables/columns, database role, append-only audit.
Secure by default	The site refuses to start with a weak secret or when opened to the network without HTTPS (SKY-CFG-002/003). Demo pages are noindex and carry a preview banner.

Principle	How SkyTech applies it
No secrets in code	Passwords and keys live only in admin-site\.env on the owner's PC (git-ignored); push-to-github.bat scans every file before upload (SKY-SEC-004).
Everything is traceable	Every request has a reference; security events, changes and errors are logged (files, dbo.AuditLog, dbo.ErrorLog) with secrets redacted.
Recoverable	Verified, checksummed database backups; all SQL scripts are re-runnable; every release is a git tag on a private GitHub repository.
Honest and lawful	Free licensed data sources only, no bot scraping of Google Maps/Yelp/Facebook, owner makes all calls (TCPA), no invented reviews or credentials on demo sites.

2. Data classification

Class	Examples	Where it is kept	Protection
Restricted	Admin password hashes, SESSION_SECRET, DB password, GitHub sign-in, API keys	admin-site\.env, dbo.AdminUsers (hash only), Windows Credential Manager	Never in git or logs (redacted); bcrypt cost 12; rotate on any suspicion
Confidential	Lead pipeline, notes, call outcomes, deal values, audit and error logs	SkyTechCRM on the owner's PC, logs\runtime, private GitHub repo (no logs)	Sign-in required; admin-only writes; append-only audit; 30-day log retention
Internal	Program documents, prompts, agent role files, code	Repository, Claude project	Private repo; versioned; no AI metadata in documents
Public	Business facts from public sources (name, phone, address), published demo sites after approval	Lead tables, demo-sites	Source recorded for every row; demos noindex until the business approves

3. Trust boundaries



Boundary	What crosses it	Controls
B4 PC ↔ Claude (SkyTech_Manager)	The local folder, connected through the Claude desktop app	Owner-approved actions only (automatic approval off); no passwords or tokens ever requested; delete rights only when granted
B5 Demo pages ↔ the public	Static demo pages copied from the local folder to hosting after approval	No forms, no scripts from third parties, photos only from allowed free-licence hosts, noindex until approved

4. Threat model (STRIDE)

Threat	Example for SkyTech	Controls in place	Codes
Spoofing	Someone signs in as the owner (guessing or stolen password)	bcrypt hashes; password policy (12+ chars, mixed case, digit, not common); 5-try lockout per user and per computer; timing-safe check with dummy hash (no user enumeration); session regenerated at sign-in	SKY-AUTH-001/002/006
Tampering	A malicious web page makes the browser change data (CSRF); SQL injection	CSRF token on every change; Origin/Referer check; SameSite=Strict cookies; parameterised SQL; table/column allow-list (schema.js); input checks (slug, colours, photo hosts)	SKY-SEC-001/007/005, SKY-DATA-006
Repudiation	A change cannot be traced to a person	dbo.AuditLog for every sign-in and change, protected by trigger (append-only); request IDs in logs	SKY-SEC-006
Information disclosure	Leads or secrets leak (logs, GitHub, error pages, other sites)	Loopback binding; no stack traces to the browser; redaction in logs; secret scan; git-ignore; no-store cache on API; strict CSP; Referrer-Policy same-origin	SKY-SEC-004, SKY-CFG-003
Denial of service	Request floods or very large requests make the site unusable	Rate limit 300/min (60 writes/min) per computer; 200 kB request limit; DB timeouts (15 s connect / 30 s query)	SKY-SEC-002/003, SKY-DB-007
Elevation of privilege	A viewer performs admin actions; the app changes database design	Server-side role check on every write (adminOnly); SkyTechApp role has no ALTER/CREATE; DENY on audit/error log changes and on backup/purge procedures	SKY-AUTH-005, SKY-DB-008

5. Controls and standards mapping

References: OWASP Application Security Verification Standard 4.0.3 (ASVS), NIST Cybersecurity Framework 2.0 (CSF), CIS Critical Security Controls v8 (CIS). Code locations are documented in the Code Documentation.

Control	Implementation	ASVS	NIST CSF	CIS
Secure configuration check at start	security.checkConfig, server.js fatal(), npm run doctor	V14.1	PR.PS-01	4.1
Strong password storage	bcryptjs cost 12 (create-admin.js); hash only in dbo.AdminUsers	V2.4.1	PR.AA-01	5.2
Password policy	security.passwordPolicy (12+, upper/lower, digit, no username, not common)	V2.1.1, V2.1.7	PR.AA-01	5.2
Brute-force protection	security.loginGuard: 5 failures / 15 min per user and IP	V2.2.1	PR.AA-03	6.x
No user enumeration	Same message and timing for unknown user (dummy bcrypt hash)	V2.2.3	PR.AA-03	—
Session management	express-session, HttpOnly + SameSite=Strict (+Secure/___Host- on HTTPS), regenerate at sign-in, 30 min idle / 8 h absolute	V3.2, V3.3, V3.4	PR.AA-05	6.2
Access control	auth + adminOnly middleware; viewer read-only; schema allow-list	V4.1, V4.2	PR.AA-05	6.8
CSRF protection	Per-session token in X-CSRF-Token + Origin check	V4.2.2	PR.PS-06	16.x

Control	Implementation	ASVS	NIST CSF	CIS
Injection prevention	Typed SQL parameters (mssql); identifiers only from schema.js; HTML escaping in app.js and render.js	V5.3.4, V5.3.3	PR.PS-06	16.x
Input validation	Required fields, types, lengths, slug/colour/photo-host checks	V5.1	PR.PS-06	16.x
Security headers	CSP (script-src 'self'), X-Frame-Options DENY, nosniff, Referrer-Policy, Permissions-Policy, COOP/CORP, HSTS on HTTPS	V14.4	PR.PS-01	16.x
Rate limiting / size limits	security.rateLimit; express.json 200 kB	V11.1.4, V13.1	PR.IR-04	13.x
Error handling	Central handler: code + ref to the user, details only in the log; catalog-based messages	V7.4.1	DE.AE-02	8.x
Security logging	logger.security for sign-in, lockout, CSRF, rate limit, permission, expiry; redaction; retention 30 days	V7.1, V7.2, V7.3	DE.CM-01, DE.AE-03	8.2, 8.5
Audit trail	dbo.AuditLog append-only (trigger, DENY)	V7.2.2	PR.PS-04	8.5
Least-privilege database role	SkyTechApp role (sql/06)	V1.4.3	PR.AA-05	5.4, 6.8
Secrets management	.env only, git-ignored, secret scan before push, doctor checks	V6.4.1, V14.3	PR.DS-01	3.x, 16.x

Control	Implementation	ASVS	NIST CSF	CIS
Backup and recovery	usp_BackupSkyTechCRM (CHECKSUM, COMPRESSION, VERIFYONLY); doctor warns after 7 days	—	PR.DS-11, RC.RP-01	11.2, 11.4, 11.5
Supply chain	Few, well-known npm packages; package-lock.json committed; npm audit in the monthly checklist	V14.2	GV.SC-04	16.4
Change management	Versioned files and footers, CHANGELOG, git tags per release, owner approval before every action	V1.1	PR.PS-02	4.x

6. Secrets and key management

Secret	Used for	Stored in	How to rotate
SESSION_SECRET	Signs session cookies	admin-site\.env	npm run doctor -- --new-secret; change if the PC or .env may have been exposed (everyone is signed out)
Admin site passwords	Owner/viewer sign-in	dbo.AdminUsers (bcrypt hash)	npm run create-admin with the same username
DB_PASSWORD (only if DB_AUTH=sql)	SkyTechAdminSite SQL login	admin-site\.env	SSMS: ALTER LOGIN SkyTechAdminSite WITH PASSWORD = N'!..!'; then update .env
GitHub sign-in	Push releases	GitHub Desktop / Windows Credential Manager	github.com → Settings → Sessions / tokens; sign in again

Secret	Used for	Stored in	How to rotate
Free API keys (Google Places check, Pexels) — if added	Lead checks, photos	admin-site\.env only	Rotate in the provider's console; never paste into documents or prompts

7. Logging, monitoring and audit

Part	Where	What is recorded
Admin site	logs\runtime\admin-YYYY-MM-DD.log	One JSON line per event: ts, level, category (http, auth, security, db, demo, startup), msg, code, reqId, user, ip, status, ms. Every API call, sign-in, logout, CSRF/rate-limit block, permission refusal and error is recorded.
Doctor	logs\runtime\doctor-YYYY-MM-DD.log	Each check and its result, with the code.
Scripts (Node + Python)	logs\runtime\scripts-YYYY-MM-DD.log	build-demos, lead builders, document builders: start, files written, failures with code and (for crashes) the traceback.
Database	SkyTechCRM.dbo.ErrorLog	One row per failure caught inside a SkyTech procedure: time, procedure, SQL error number, line, message, SkyTech code, context, login, computer.
Database audit	SkyTechCRM.dbo.AuditLog	Who signed in, created, changed, merged or deleted what (append-only; protected by trigger, SKY-SEC-006).

- Levels: debug < info < warn < error. LOG_LEVEL in .env picks the minimum written (default info).
- Passwords, hashes, secrets, tokens, cookies and CSRF values are replaced by [redacted] before anything is written.
- Files older than LOG_RETENTION_DAYS (default 30) are deleted automatically; the logs\runtime folder is git-ignored and never uploaded.
- The ref shown on screen (X-Request-Id) is the reqId in the log — search for it to see exactly what happened.
- If the log folder cannot be written the site keeps running and logs to the screen only (SKY-SYS-003).

8. Backup and recovery

Backup: EXEC SkyTechCRM.dbo.usp_BackupSkyTechCRM; — full, compressed backup with page checksums, verified with RESTORE VERIFYONLY, to C:\SkyTechBackups (weekly; the doctor warns after 7 days, SKY-BAK-003). Keep a copy off the PC.

Recovery point: up to one week of changes (daily backups shorten this). **Recovery time:** under one hour (restore, re-run sql/04 and sql/06, doctor).

Code and documents: every release is a git tag on the private GitHub repository.

9. Incident response

Step	What to do
1. Detect	Signs: unexpected LOCKOUT or LOGINFAIL entries, SKY-SEC-001/007 blocks you did not cause, unknown changes in dbo.AuditLog, doctor warnings, a secret-scan hit.
2. Contain	Stop the Admin site (close its window). If a secret may be exposed: change it now (table above). If the PC may be compromised: disconnect it from the network.
3. Investigate	System log / logs\runtime (search by ref, user, ip), dbo.AuditLog and dbo.ErrorLog queries in the Troubleshooting Guide, git log for unexpected commits.
4. Recover	Restore the newest verified backup if data was damaged (SKY-BAK-002 recipe), re-run sql/04 and sql/06, create new admin passwords, run the doctor.
5. Learn	SkyTech_Manager records what happened, the fix and any new control in the CHANGELOG and the version register; add or update the error code.

10. Owner security checklist

When	Tasks
Every day	Start with start-admin.bat (runs the doctor). Glance at the System log for red (error) rows.
Every week	EXEC dbo.usp_BackupSkyTechCRM; in SSMS; copy C:\SkyTechBackups to a USB drive or cloud folder. Run npm run doctor. Push releases with push-to-github.bat (secret scan runs).
Every month	Install Windows and SQL Server updates. In admin-site run npm audit (report findings to SkyTech_Manager). Review AdminUsers (remove unused logins). Review dbo.ErrorLog and purge rows older than 90 days.

When	Tasks
Every quarter	Test a restore of the newest backup into a scratch database (RESTORE ... WITH MOVE, under another name). Change SESSION_SECRET and admin passwords. Review this document with SkyTech_Manager.

11. Known limits and roadmap

Limit	Why it is acceptable now / what changes later
Single computer	Sessions, rate-limit and lockout counters are kept in memory; restarting the site signs everyone out and clears locks. Fine for one owner; a shared store is needed before hosting for several users.
No multi-factor sign-in yet	Acceptable while the site is reachable only from this PC (127.0.0.1). Required before any internet exposure (roadmap).
Local HTTP	Traffic never leaves the PC, so HTTPS is not needed locally; any other HOST requires HTTPS (enforced, SKY-CFG-003).
Database encryption at rest	SQL Server 2014 Developer supports TDE, but backups and the PC disk are best protected with Windows BitLocker (owner setting).
Not a certification	Controls follow OWASP ASVS, NIST CSF 2.0 and CIS Controls v8 practices scaled to a one-PC business. No external audit has been performed.

Version: V1.0 (2026-10-10) — docs/architecture/SkyTech_Security_Architecture.html — V1.0. Rebuild with: python scripts/docs/build_ops_docs.py